

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

Postman Authentication Workflow and JWT Capture Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	Postman login + JWT
Result Type	Auth workflow captured
Evidence Report File	02-postman-login-jwt-token-evidence-report.pdf
Testing Phase	Authentication Flow Capture
Tool / Component	Postman API Client
OWASP / Security Mapping	API2:2023 Broken Authentication
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

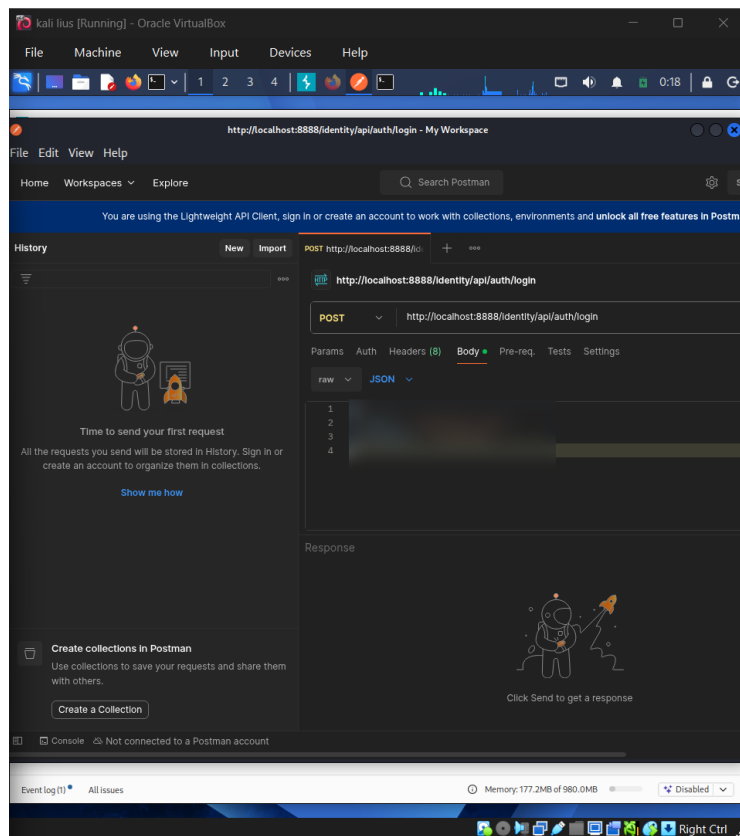


Figure 1 - Embedded screenshot evidence for: Postman login + JWT

What this evidence proves

The screenshot shows the login API endpoint being prepared in Postman with a JSON request body. Sensitive request content is blurred, which is appropriate because login workflows may contain credentials or token material.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	Authentication Flow Capture
Tool / Component	Postman API Client
Assessment Objective	Capture the login workflow and show that authentication is performed through an API request returning token-based session material.
Result Type	Auth workflow captured
OWASP / Security Mapping	API2:2023 Broken Authentication

Why this evidence matters

Authentication workflow capture is essential before testing authorization, BOLA/IDOR, JWT controls, rate limits, and authenticated endpoint behaviour.

Command / workflow used

```
POST /identity/api/auth/login
Content-Type: application/json
{
  "email": "<REDACTED_EMAIL>",
  "password": "<REDACTED_PASSWORD>"
}
# Review response for JWT / bearer token
```

Sanitized output style

```
HTTP request prepared in Postman
Credentials: <REDACTED>
Token response: <REDACTED>
Next step: use token in authenticated tests
```

3. Professional Interpretation

This evidence row should be interpreted as: **Auth workflow captured**.

If credentials or JWTs are exposed, an attacker may replay authenticated requests. If the token is long-lived or weakly validated, the impact can expand to account takeover or unauthorized API access.

Assessor notes

This evidence should always be heavily redacted before GitHub upload.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Finding interpretation

Where the evidence shows vulnerable behaviour, the report should explain the security impact, the affected object or workflow, and the remediation without publishing sensitive raw values.

4. Risk, Impact, and Remediation Guidance

Risk perspective

If credentials or JWTs are exposed, an attacker may replay authenticated requests. If the token is long-lived or weakly validated, the impact can expand to account takeover or unauthorized API access.

Recommended remediation / hardening actions

- Use HTTPS for all authentication traffic.
- Never expose credentials in screenshots or commits.
- Use short-lived access tokens and refresh token rotation.
- Apply secure token storage and revocation controls.
- Audit authentication endpoints for brute-force protection.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Email addresses.
- Passwords.
- JWT access tokens.
- Bearer tokens.
- Refresh tokens.
- Authorization headers.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

[Postman login + JWT](./reports/evidence/02-postman-login-jwt-token-evidence-report.pdf)

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.